

SECURITY INCIDENT PRESENTATION

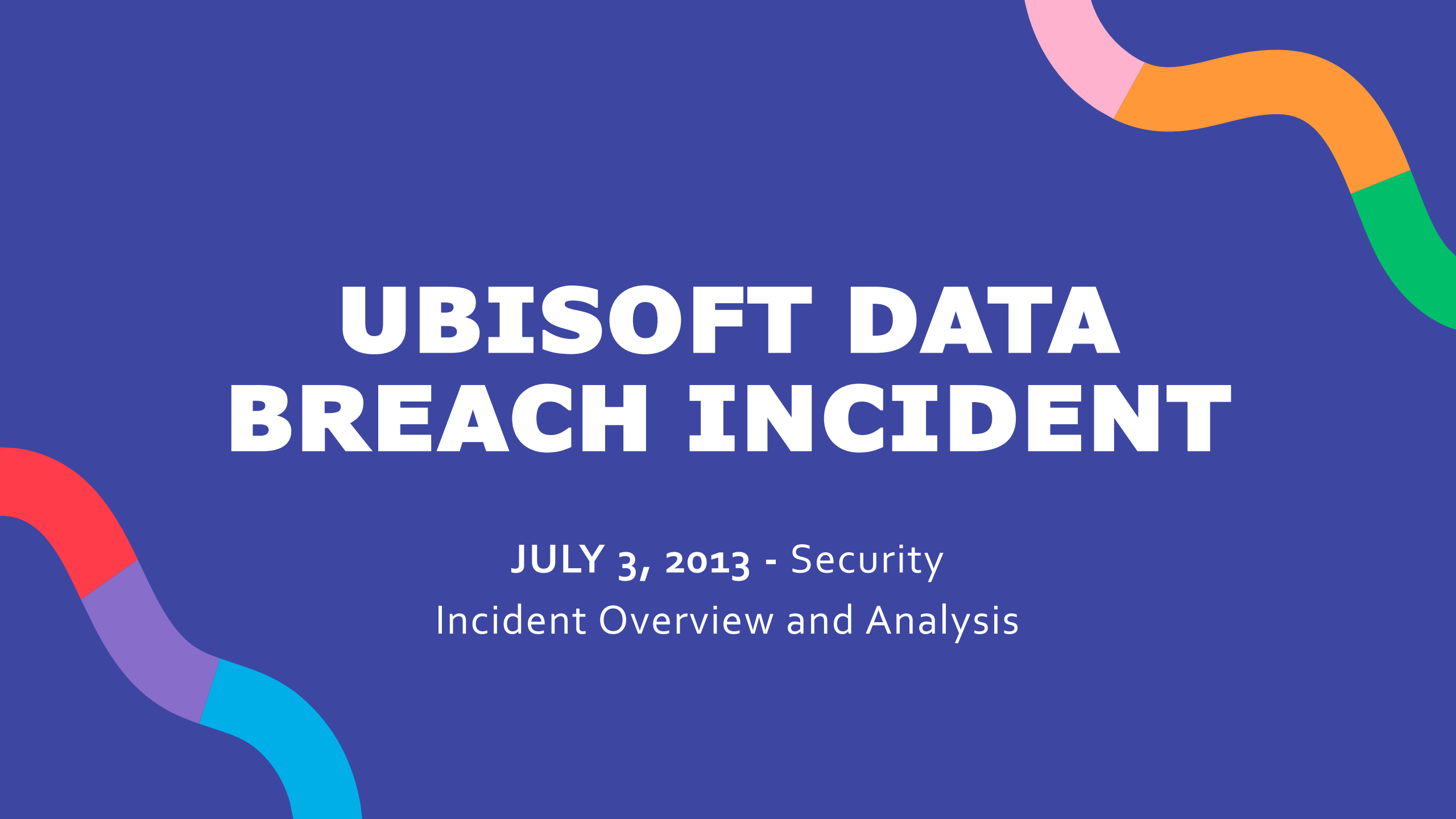
INCIDENT RESPONSE AND HANDLING CAPSTONE

Group 2: Timothy Loudon, Melvin Viado, Daniel
Lindo, Emmanuel Ajayi

MGMT 1212: Incident Handling and Response

Data Breaches: Ubisoft, Discord





UBISOFT DATA BREACH INCIDENT

JULY 3, 2013 - Security
Incident Overview and Analysis

INTRODUCTION

COMPANY OVERVIEW AND INDUSTRY CONTEXT



Ubisoft's Global Role

- The leading global video game publisher
- Known for popular franchises and online platforms.

Gaming Industry Security Challenges

- Prioritizes performance and user experience
- Faces unique cybersecurity risks.

Significance of Data Breach

- 2013 data breach exposed Ubisoft's security weaknesses
- Highlights risk to user data and brand trust

Need for Proactive Security

- Shows importance of adopting advanced security controls (MFA)

NATURE OF THE SECURITY INCIDENT

(a) Suspicious system and network activities

- The breach was discovered after Ubisoft's security teams detected unauthorized activity within their network environment.

(b) Compromise of sensitive information

- Attackers successfully accessed the account database
- Usernames, email addresses, and encrypted passwords exposed for approximately 58 million users

(c) Unauthorized access or attempts to access a system

- Exploited the vulnerability on a Ubisoft website
- Allowed the attackers to gain illegal access to their internal systems.

(i) Social engineering / Account compromise

- Attackers used the compromised administrative rights
- Attackers navigated the systems and access the user database



NATURE OF THE SECURITY INCIDENT CATEGORIES THAT DO NOT APPLY

Denial of Service (e)

- The goal was data theft, not taking the servers offline.

Malware (g)

- The breach is primarily classified as an exploit of a web vulnerability
- Not a widespread malware infection

Tampering (f)

- The breach was a digital network breach
- Not a physical compromise of hardware.



INCIDENT SEVERITY AND IMPACT ASSESSMENT

Metric	Impact Detail
Total Accounts Affected	~58 Million
Data Types Stolen	Username, Email Address, Encrypted Passwords
Financial Data	No credit card or payment info was compromised (stored separately)
Response Action	Mandatory global password reset and security overhaul

(e) Very High (impact's organization's entire infrastructure/privileged accounts)

Impact Beyond the Organization

- Breach exposed personal data of 85 million users

Widespread Risk

- Forced a global password reset for all Ubisoft accounts
- Users had to secure other accounts if they practiced password reuse
- The threat extends across the internet.

Exploitation of Authority

- Admin access gained by exploiting a vulnerability in a Ubisoft website
- Attackers pivoted through the internal network to reach the account database

DETECTION AND INVESTIGATION PROCESS



Breach Detection

- Found suspicious activities via monitoring systems:
 - Anomalous authentications
 - Unusual access patterns

Internal Investigation

- Actions for threat containment:
 - Compromised credentials
 - Accessed systems
 - Assessing data exposure

External Coordination

- Collaborated with external parties
- Helped understand credential compromise
- Mitigated risks to prevent further breaches

Eradication and Recovery

- Password resets
- Strengthened access controls

EXPLOIT AND ATTACK VECTOR DESCRIPTION

Credential-Based Attack

Attackers used external parties to understand compromised credentials

Methods of Compromise

Phishing

Malware

Weak passwords

Poor third-party security

Over-Privileged Access Risks

Lack of least privilege enforcement

Defense and Mitigation

Robust third-party controls

Continuous authentication

Monitoring



SENSITIVITY OF COMPROMISED DATA

Compromised Personal Data

- Potentially sensitive personally identifiable information compromised:
 - Usernames
 - Email addresses
 - Hashed passwords

Password Security Risks

- Increases the risk of attackers recovering plaintext passwords
 - Weak hashing algorithms
 - Password reuse

Cascading Security Threats

- Password reuse across platforms = broader account compromises

Compliance and Protection

- Exposure of PII triggers:
 - Notification duties
 - Importance of protecting authentication data



CONTROLS TO PREVENT RECURRENCE

Third-Party Risk Management

- Regular vendor security assessments
- Strict access limits

Multi-Factor Authentication

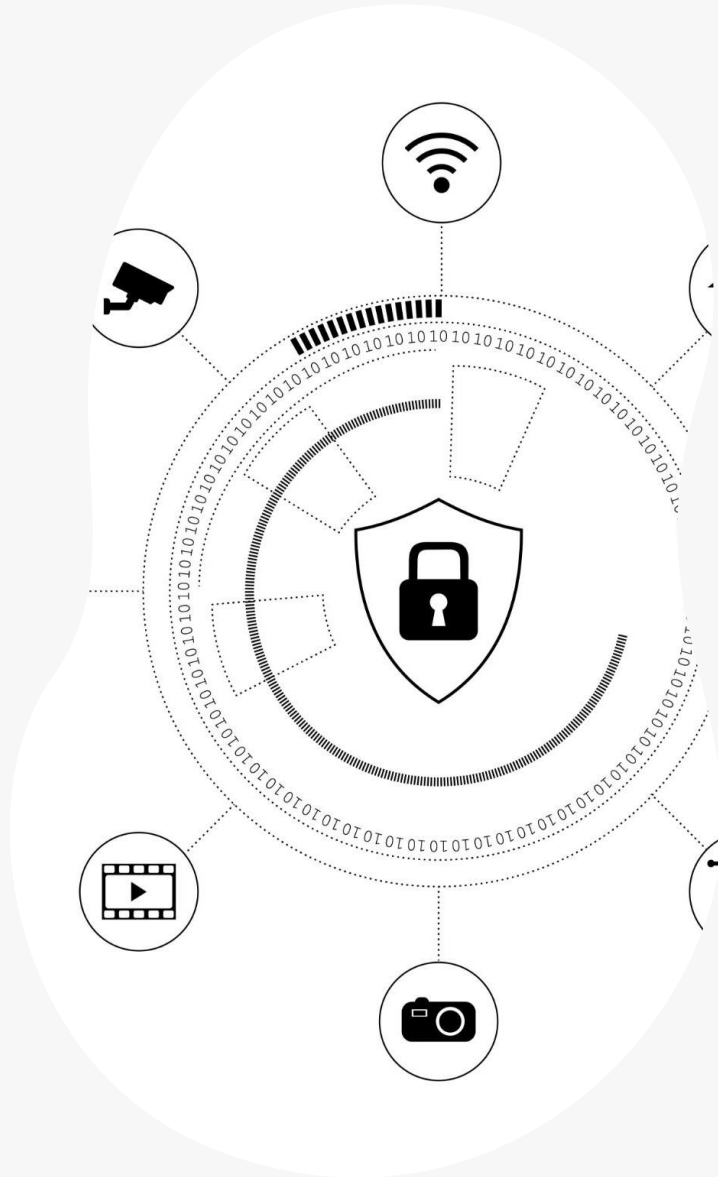
- Extra security layer
- Credentials alone is insufficient

Enhanced Monitoring and Detection

- Real-time alerts
- Behavior analytics

User Awareness and Training

- Educating employees security



CONCLUSION AND LESSONS LEARNED

Breach Summary

- Exposed sensitive account data
- Revealed Ubisoft's access control weaknesses

Importance of Strong Controls

- Reduces credential-based attack risks:
 - Strong authentication
 - Least-privilege access
 - Continuous monitoring.

Effective Incident Response

- Limit damage and maintain user trust via:
 - Proactive incident response
 - Transparent communication limit

Continuous Security Improvement

- Ongoing learning against evolving cyber threats:
 - Strengthen defenses
 - Improve resilience





DISCORD BREACH

JULY 3, 2013 - Security Incident Overview and Analysis



DISCORD

INTRO TO DISCORD.IO

Company that provides users with a way to make custom vanity URLs for their Discord server

Technology company focusing on customization for a different service

NATURE OF THE INCIDENT

On August 14, 2023, an attacker known as Akhirah exploited a vulnerability in the web server that allowed them to download the entire customer database.

Personally Identifiable Information such as email addresses were exposed along with encrypted passwords and some financial information of a few users.



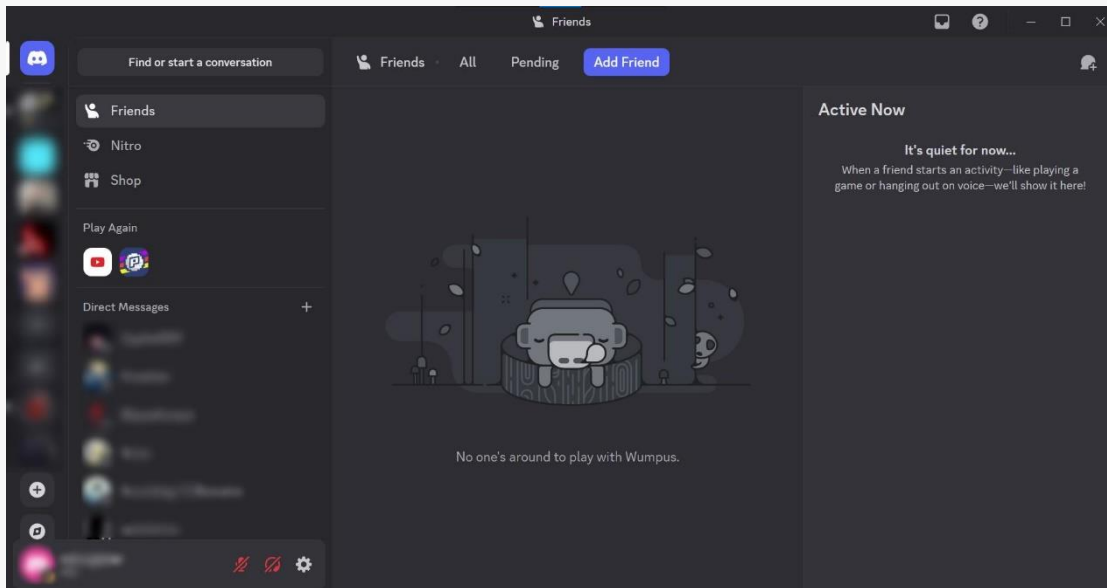
INCIDENT SEVERITY

Due to the wide array of information that was exfiltrated, this is a very severe incident and led to Discord.io going out of business.

The impact on customers was just as severe, requiring them to change passwords on all sites they have accounts on, monitor their financials in the event of fraud, and ruining the reputation of Discord.io.



HOW THE BREACH WAS DISCOVERED



The breach was first posted on an online breach forum website before it was found by site administrators 16 hours later.

When the administrators discovered that their database had been leaked, they confirmed the breach and took the website offline within 10 minutes.

EXPLOIT DESCRIPTION

Discord.io's website code allowed unauthorized access to the database and backend systems

The attacker was able to reach the production database directly

Then attacker (Akhirah) then exfiltrated the entire user database, totalling over 700,000 accounts

The stolen database was then posted for sale



SENSITIVITY OF COMPROMISED DATA

Personally identifiable data, such as emails, usernames and Discord IDs were exfiltrated from the database

Hashed and salted passwords were leaked, resulting in users needing to reset their passwords in fear of their account being compromised

Billing addresses and transaction metadata were exposed

API keys and internal tokens were compromised

Thankfully, credit and debit card information was not leaked, as Discord.io did not manage that information



CONTROLS THAT COULD PREVENT REOCCURRENCE

What additional controls should be in place to prevent the incident reoccurring?

ISO 27001:0222 A.5.18: This control is in relation to privileged access rights, to enforce least privilege for database access, routing rotations of API keys, and the implementation of MFA for admin access.

ISO 27001:2022 A8.24: This is a Cryptographic control that enforces strong hashing practices, encrypting sensitive data both in transit and at rest, and the removal of unnecessary data retention.

ISO 27001:2022 A5.32: This control handles intellectual property rights, to ensure there is compliance with intellectual property laws, as Discord.IO has no relation to Discord itself.

ISO 27001:2022 A5.19: This control handles formal vendor risk assessments that are conducted routinely, and the use of annual penetration tests. This would aid in overcoming vulnerabilities that may not have been discovered yet, aiding reducing the occurrence of a breach.

CONCLUSION

Akhirah was able to breach Discord.io's user database with frightening ease, resulting in the exfiltration of many premium subscriber user accounts.

Sensitive information was leaked, however important details like card information was thankfully kept safe, relative to the rest of the breach.

As a response to the breach, Discord.io refunded those who were affected, and chose to take down their platform indefinitely

Situations such as this highlight why making use of effective access controls, and business continuity plans is essential to the online market, as a breach is a matter of time, and requires effective planning to overcome.

